

Clase 011 — Protocolos de red: IP, TCP, UDP e ICMP en profundidad

Parte: **0 — Fundamentos y prerequisites** · Fuente: *RFC 791, 793 y W. R. Stevens, TCP/IP Illustrated* 

Duración estimada: **110 min** · Nivel: **Fundamentos**

Objetivo

Conocer al detalle los protocolos que mueven Internet: cómo se estructuran sus cabeceras, cómo TCP establece y cierra conexiones, en qué se diferencia UDP y para qué sirve ICMP. Este conocimiento es la base del escaneo de puertos, la detección de intrusiones y muchos ataques de red.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Interpretar** los campos clave de las cabeceras IP, TCP, UDP e ICMP.
2. **Explicar** el three-way handshake y el cierre de conexión TCP.
3. **Distinguir** TCP de UDP y cuándo se usa cada uno.
4. **Relacionar** flags y estados TCP con técnicas de escaneo.
5. **Analizar** una conversación real en Wireshark.

Temas

#	Tema	Por qué importa
1	Cabecera IP	TTL, protocolo, fragmentación
2	Three-way handshake	SYN, SYN-ACK, ACK
3	Flags TCP	SYN, ACK, FIN, RST, PSH, URG
4	Estados TCP	LISTEN, ESTABLISHED, TIME_WAIT...
5	Ventana y secuencia	Fiabilidad y control de flujo
6	UDP	Sin conexión, base de DNS/DHCP
7	ICMP	Diagnóstico y su abuso
8	Escaneo de puertos	SYN, connect, FIN, UDP scan

Definiciones y características

- **TTL (Time To Live):** contador de saltos en la cabecera IP; cada router lo decrementa. Clave: a 0 se descarta y se usa en `traceroute` y para inferir el SO.

- **Three-way handshake:** SYN → SYN-ACK → ACK que abre una conexión TCP. Clave: base del `connect scan` y del SYN flood.
- **Flag RST:** reinicio abrupto de conexión. Clave: un puerto TCP cerrado responde con RST; así el escáner sabe que está cerrado.
- **UDP:** transporte sin conexión ni garantías. Clave: rápido, sin handshake; DNS, DHCP, VoIP lo usan.
- **ICMP:** protocolo de control/diagnóstico (echo request/reply, unreachable). Clave: `ping` y `traceroute`; también usado para túneles y exfiltración.
- **Número de secuencia:** identifica la posición de los bytes en el flujo TCP. Clave: su predictibilidad histórica permitió ataques de spoofing.

Herramientas y preparación

Usa **Wireshark**, **tcpdump**, y **nmap** en tu laboratorio aislado. Para generar tráfico controlado, `curl`, `ping`, `nc`. Conviene tener a la vista los diagramas de cabecera de los RFC 791 (IP) y 793 (TCP).

Laboratorio guiado

1. **Capturar un handshake.** En Kali, arranca la captura y luego conéctate a un servicio de la víctima:

```
bash sudo tcpdump -i eth0 -n 'tcp and host 10.10.10.6' -w tcp.pcap & curl http://10.10.10.6/ ;
sudo pkill tcpdump
```

2. **Analiza en Wireshark** el filtro `tcp.flags.syn == 1`. Identifica SYN, SYN-ACK y ACK y anota números de secuencia y puertos.
3. **Cierre de conexión.** Localiza los paquetes FIN/ACK (o RST) al final de la conversación.
4. **Escaneo SYN** (half-open) contra tu víctima:

```
bash sudo nmap -sS -p 1-1000 10.10.10.6
```

Captura en paralelo y observa que a puertos cerrados llega **RST** y a abiertos, **SYN-ACK**. 5. **UDP e ICMP.** Lanza un ping y un escaneo UDP:

```
bash ping -c 3 10.10.10.6 sudo nmap -sU -p 53,67,123 10.10.10.6
```

Observa las respuestas ICMP "port unreachable" para puertos UDP cerrados. 6. **TTL fingerprinting.** Compara el TTL de respuestas de un Linux (~64) y un Windows (~128) en tu laboratorio.

 **Nota ética:** los escaneos se ejecutan **solo** contra tus VMs de laboratorio o con autorización explícita. `nmap` contra terceros sin permiso puede constituir delito.

Ejercicios

1. Dibuja el three-way handshake indicando qué flag lleva cada paquete.
2. Explica qué respuesta da un puerto TCP abierto, cerrado y filtrado ante un SYN scan.
3. ¿Por qué el escaneo UDP es más lento y menos fiable que el TCP?
4. Interpreta el campo TTL de tres capturas y estima el SO de origen.
5. Explica la diferencia entre `-sS` (SYN) y `-sT` (connect) en `nmap` y sus implicaciones de sigilo.
6. Describe cómo ICMP puede usarse para exfiltrar datos (túnel ICMP) y cómo detectarlo.

Reto verificable

Realiza y documenta un escaneo comparativo contra tu VM víctima: un SYN scan y un connect scan sobre el mismo rango, capturando ambos en Wireshark. Entrega una tabla que muestre, para 3 puertos (uno abierto, uno cerrado, uno filtrado), qué paquetes se intercambiaron en cada tipo de escaneo.

Criterio de aceptación: la tabla refleja correctamente las respuestas (SYN-ACK/RST/sin respuesta) y explica por qué el SYN scan no completa el handshake mientras el connect sí. Las capturas adjuntas respaldan cada fila.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Todos los puertos aparecen "filtered"	Un firewall descarta los paquetes. Ajusta el escenario o usa <code>-Pn</code> /timing distinto.
nmap SYN scan requiere root	El SYN scan usa paquetes crudos. Ejecuta con <code>sudo</code> .
UDP scan tarda muchísimo	Es normal: sin respuesta, nmap espera y reintenta. Limita puertos.
Confundir puerto cerrado con filtrado	Cerrado responde (RST/ICMP); filtrado no responde. Distínguelos por la respuesta.
TTL no coincide con el esperado	Hubo saltos intermedios (routers). Cuenta relativo al valor inicial típico.

Preguntas frecuentes

¿Por qué el SYN scan es "sigiloso"? Porque no completa el handshake (envía RST tras el SYN-ACK), por lo que muchas apps no registran la conexión. Aun así, los IDS modernos lo detectan.

¿UDP es "inseguro" por no tener handshake? No es inseguro por sí mismo; simplemente no garantiza entrega ni orden. Protocolos sobre UDP (DNS, QUIC) añaden sus propias garantías o cifrado.

¿Se puede bloquear todo ICMP sin consecuencias? No conviene: rompes diagnóstico (ping, PMTUD). Filtra selectivamente en lugar de bloquear ICMP por completo.

¿Los números de secuencia siguen siendo predecibles? Los SO modernos los aleatorizan (ISN), mitigando el spoofing clásico. Es un buen ejemplo de cómo una debilidad de diseño se corrige con el tiempo.

Referencias

- RFC 791 (IP) — <https://www.rfc-editor.org/rfc/rfc791>
- RFC 793 (TCP) — <https://www.rfc-editor.org/rfc/rfc793>
- Nmap Reference Guide — <https://nmap.org/book/man.html>
- W. R. Stevens, *TCP/IP Illustrated, Vol. 1*.

Siguiente clase

Clase 012 - DNS, DHCP y ARP: funcionamiento y riesgos